

Cirque Corporation

Vulnerability Management Policy

Document ID: IS-CIRQ-P-034-G

Category: Technical Controls

Division: Policy

Type: Global

Version: 1.0

Effective Date: March 2026

Review Date: March 2027

Approved By: CTO, CISO

Generated: March 02, 2026

1. Introduction

Identifying and remediating security vulnerabilities is essential to protecting Cirque Corporation's systems and data from cyber threats.

2. Purpose

This policy establishes requirements for identifying, assessing, prioritizing, and remediating security vulnerabilities in information systems, applications, and infrastructure.

3. Scope

This policy applies to all information systems, applications, network devices, servers, workstations, and cloud services used by Cirque Corporation.

4. Vulnerability Scanning

Vulnerability scans shall be conducted:

- Quarterly for all production systems (minimum)
- Monthly for internet-facing systems (recommended)
- After significant system changes
- Before deployment of new systems
- Using authenticated scanning where possible
- Covering all network segments and system types

5. Penetration Testing

Independent penetration testing shall be conducted:

- Annually for internet-facing applications and infrastructure
- For new critical applications before production deployment
- By qualified external security professionals
- With appropriate scope and rules of engagement
- With management awareness and approval

6. Vulnerability Assessment

Identified vulnerabilities shall be assessed for:

- Severity level (Critical, High, Medium, Low based on CVSS scores)
- Exploitability and threat landscape
- Affected systems and data sensitivity
- Business impact of exploitation
- Compensating controls

7. Remediation Requirements

Vulnerabilities shall be remediated according to severity:

- Critical: Within 7 days or apply compensating controls
- High: Within 30 days
- Medium: Within 90 days
- Low: Within 180 days or accept risk

Exceptions require documented risk acceptance by management.

8. Patch Management

Security patches shall be:

- Evaluated promptly upon release
- Tested in non-production environment
- Deployed according to vulnerability severity
- Automated where possible for critical infrastructure
- Documented with deployment dates and systems affected

9. Emergency Patching

For actively exploited critical vulnerabilities:

- Emergency change process may be invoked
- Patches may be deployed rapidly with limited testing
- Systems should be monitored closely after deployment
- Full testing and validation conducted afterward

10. Vulnerability Tracking

All vulnerabilities shall be tracked in a vulnerability management system including:

- Discovery date and method
- Affected systems
- Severity and risk rating
- Assigned owner
- Remediation plan and timeline
- Status updates
- Verification of remediation

11. Reporting

Vulnerability management metrics shall be reported monthly to IT management and quarterly to executive leadership including:

- Number of vulnerabilities by severity
- Mean time to remediation
- Overdue remediation items
- Trends and risk areas